SUPPORT ÉTUDIANT

DSP2 et Open Banking

Jour 1 : Du modèle bancaire fermé à la directive

Chrisvene MPANDZOU

chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Sommaire

Repères de lecture du polycopié

01 Introduction & objectifs 3

02 Le modèle bancaire fermé 7

03 DSP1 · D'où l'on vient 10

04 La DSP2 en fiche 14

05 Les autorités européennes 19

06 L'Open Banking hors d'Europe 22

07 S1 · Le problème 25

08 S2 · La réponse 30

09 S3 · La machine 37

Introduction & objectifs

ACCUEIL

Intro & objectifs

Avant d'entrer dans le détail, cette ouverture pose les mots : qu'est-ce que la DSP2, que recouvre l'appellation « Open Banking », et que va-t-on construire ensemble pendant ces cinq jours ?

LE VOCABULAIRE D'ABORD

Qu'est-ce qu'une directive européenne ?

Une **directive** est un acte juridique de l'Union européenne qui fixe un **résultat à atteindre**, en laissant chaque État membre **choisir la forme et les moyens** pour y parvenir. Elle n'est pas applicable telle quelle : elle doit d'abord être **transposée** dans le droit national — par une loi, une ordonnance ou un décret — dans un délai fixé par le texte.

Directive, règlement, décision : la différence

Le règlement s'applique directement, partout et le même jour, sans transposition : c'est le cas du RGPD. **La directive** laisse une marge d'adaptation nationale : c'est le cas de la DSP1 et de la DSP2. **La décision** vise un destinataire précis : une entreprise, un État.



Figure — adoption, transposition, application : c'est ce détour par le droit national qui explique les différences d'application de la DSP2 d'un État à l'autre.

UNE MÊME RÈGLE, DES APPLICATIONS DIFFÉRENTES

- La DSP2 fixe un résultat, pas les moyens.
- La France transpose par ordonnance, l'Allemagne par loi : le texte est le même, l'application varie.
- C'est pourquoi un même service peut être autorisé ici et restreint ailleurs — et pourquoi les autorités nationales ont un rôle décisif.
- L'**ACPR** — Autorité de contrôle prudentiel et de résolution — est précisément ce superviseur national en France.

DE QUOI PARLE-T-ON ?

DSP2 et Open Banking — deux sigles à fixer d'entrée

DSP2 signifie **Deuxième Directive sur les Services de Paiement** (en anglais : *Payment Services Directive 2*, abrégé *PSD2*). C'est une directive européenne, adoptée le **25 novembre 2015**. Elle remplace et complète la première directive sur les services de paiement.

- **DSP2 — (UE) 2015/2366.** *UE* : Parlement et Conseil. *2015* : année d'adoption. *2366* : rang de l'acte publié cette année-là — ni chapitre, ni article.
- **DSP1 — 2007/64/CE.** *2007* : année d'adoption. *64* : rang de l'acte cette année-là. *CE* : Communauté européenne, avant le traité de Lisbonne (2009) ; depuis, on écrit *UE*.

> **Open Banking** — littéralement « banque ouverte » — désigne le fait, pour une banque, d'ouvrir l'accès à ses **données de comptes** et à ses **capacités de paiement** à des tiers agréés, **avec le consentement explicite du client**. La DSP2 est le texte européen qui rend cette ouverture obligatoire et encadrée.

Retenons la nuance qui structure tout le module : **la DSP2 est la règle**, **l'Open Banking est la pratique**. La directive dit ce qui est permis, obligatoire et interdit ; l'Open Banking, ce sont les interfaces, les applications et les usages qui en découlent pour les clients et les établissements.

Trois mots à ne pas confondre

- **DSP1 / DSP2** sont des textes européens successifs.
- **Open Banking** est le modèle d'ouverture rendu possible par ces textes.
- **API** (Application Programming Interface) est l'outil technique par lequel l'ouverture se réalise : l'**interface dédiée** que la banque doit exposer aux tiers agréés.

On peut faire de l'Open Banking sans le nommer, et l'on confond souvent les trois.

LE LIEN EN UNE IMAGE

La DSP2 ouvre, l'Open Banking pratique

La DSP2 est un **texte** qui oblige ; l'Open Banking est la **pratique** qui en découle. Trois étages : la règle, le canal technique, les usages.

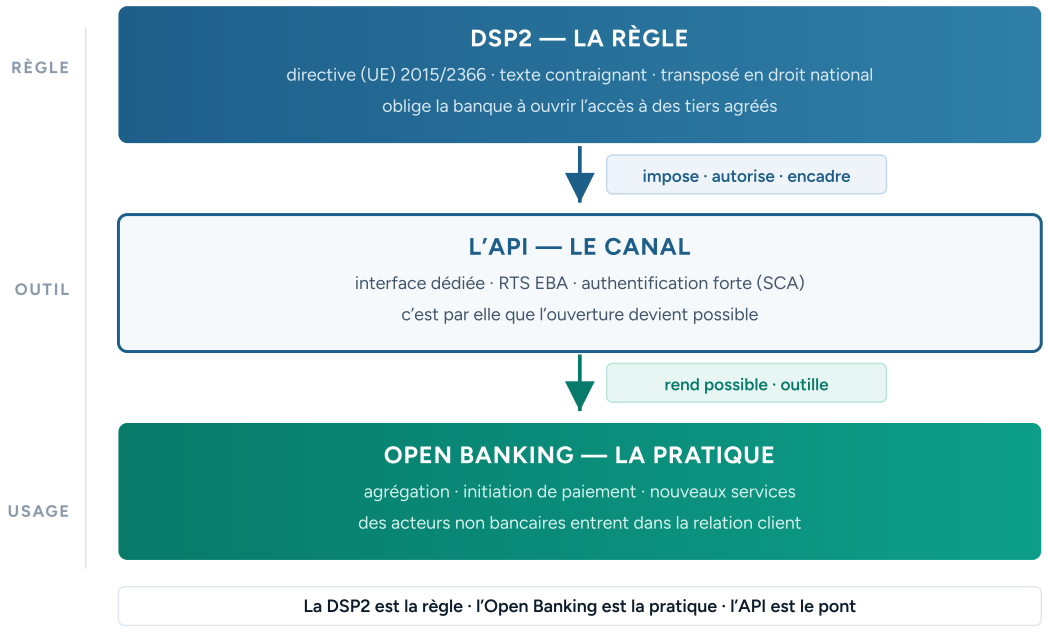


Figure — la chaîne descend du droit vers les usages. Un pays peut avoir la DSP2 sans Open Banking actif : c'est le cas quand les API existent mais que personne ne s'en sert.

APERÇU

Ce que vous allez apprendre, en une image

Le module suit une histoire : celle de Lyam, un client qui veut simplement voir tous ses comptes au même

endroit. De son histoire découle toute la logique de la DSP2 et de l'Open Banking.



Figure — le parcours de Lyam : le problème, l'incident, la réponse DSP2, l'usage aujourd'hui.

Le problème

Avant la DSP2, pour accéder aux comptes de Lyam, une application devait emprunter ses identifiants. Fragile, dangereux, sans cadre.

La réponse

La DSP2 crée de nouveaux rôles (AISP, PISP…), impose une interface dédiée aux banques et protège le consentement du client.

La machine

Côté banque, une chaîne de couches (Gateway, consentement, IAM, core) fait la médiation entre le tiers et le système de compte.

Les standards

Deux grandes familles d'API (OBIE, Berlin Group) organisent l'interopérabilité entre banques et applications.

Fil rouge du module

Lyam traverse les cinq jours. Il commence par perdre confiance dans son application de budget, puis découvre qu'un accès encadré existe. Chaque séquence répond à une question qu'il se pose.

Avant de raconter l'histoire : la fiche d'identité

Avant le récit, deux pages posent le décor. **« DSP1 · D'où l'on vient »** donne la première directive et ses limites : ce qu'elle a construit, et ce qu'elle a laissé de côté. La **« La DSP2 en fiche »** en dresse ensuite l'identité complète : où elle s'applique, ce qu'elle couvre et quelles obligations elle impose. C'est la référence à garder sous les yeux pendant tout le module.

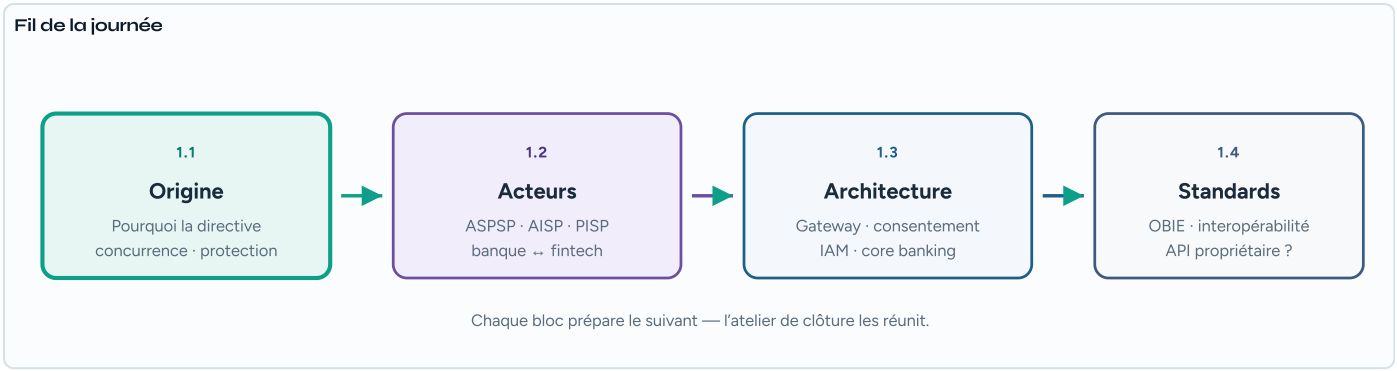
POSITIONNEMENT

Du texte réglementaire à l'architecture SI

La DSP2 (directive (UE) 2015/2366, dite « DSP2 ») n'est pas un sujet juridique isolé : elle impose à un SI bancaire d'exposer des **interfaces**, de gérer des **consentements** et d'authentifier des **tiers non bancaires**. Le fil de cette journée suit exactement ce chemin : le *pourquoi* (origine), le *qui* (acteurs), le *comment* (architecture) et le *avec quoi* (standardisation).

IDÉE DIRECTRICE DU JOUR

La DSP2 transforme la banque d'un silo fermé en *plateforme* exposant des données et des capacités de paiement à des tiers agréés — sous consentement explicite du client.



OBJECTIFS PÉDAGOGIQUES

À l'issue du Jour 1, l'étudiant sait…

- **Situer** la DSP2 : périmètre géographique (EEE), services couverts, grandes obligations et ce qu'elle change par rapport à la DSP1.
- **Expliquer** les limites du modèle bancaire fermé et les trois objectifs de la DSP2 (concurrence, innovation, protection du consommateur).
- **Distinguer** les statuts réglementaires ASPSP et TPP, et les rôles AISP / PISP / CBPII au sein des TPP.
- **Décrire** l'architecture logique d'une exposition Open Banking, de la requête du TPP jusqu'au core banking, couche par couche.
- **Identifier** les rôles du consentement et de la SCA (Strong Customer Authentication) dans un flux de paiement initié par un tiers.
- **Argumenter** un choix entre API propriétaire et API standardisée (OBIE / Berlin Group).

FIL DE SÉANCE

Parcours

CURSUS

Trajectoire des 5 jours

Programme module



02 · LE MODÈLE BANCAIRE FERMÉ

Le modèle bancaire fermé

LE POINT DE DÉPART

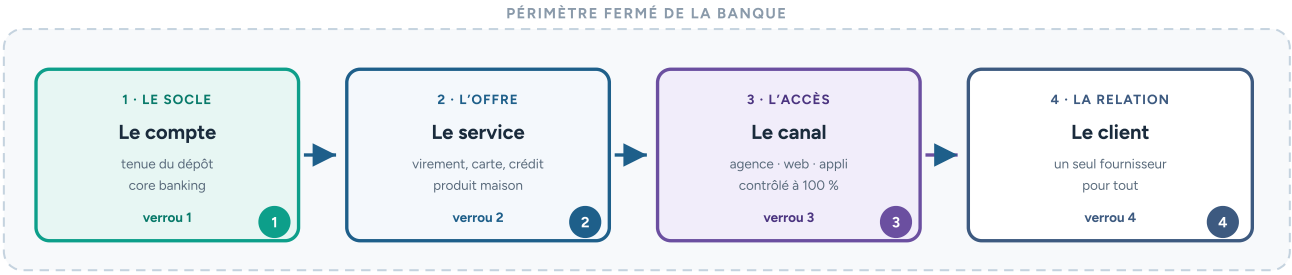
Le modèle bancaire fermé

Avant d'entrer dans le récit, il faut comprendre ce que la banque protégeait. Le modèle bancaire traditionnel n'est pas « en retard » : il est *fermé par construction*. Ce bloc pose les bases, avant le parcours narratif.

STRUCTURE

Une chaîne intégrée, du compte au client

La banque de détail historique maîtrise toute la chaîne de valeur : elle tient le compte, produit le service, contrôle le canal et possède la relation client. Chaque maillon renforce les autres — et, dans le même mouvement, **verrouille** le marché. Cliquez sur un maillon du schéma : il révèle à la fois ce qu'il protège et la limite qu'il crée.



Cliquez sur un maillon (1 à 4) : sa fonction, ce qu'il protège et le verrou qu'il crée.

1 LE COMPTE — LA DONNÉE CAPTIVE

Fonction. La banque tient le dépôt et le core banking. C'est **le socle** de toute la chaîne : sans compte chez elle, rien d'autre n'existe.

Verrou créé — la donnée n'appartient qu'à la banque. Le relevé est un actif stratégique : il alimente le cross-selling et verrouille la relation. Sans API, aucun tiers ne peut construire un service par-dessus.

- **Protège** : cohérence du SI, maîtrise du risque.
- **Empêche** : gestion de budget consolidée.
- Le client est *titulaire* du compte, mais n'a aucun moyen technique de *déléguer* la lecture de ses données. Elle existe, mais ne circule que dans le périmètre de la banque.

2 LE SERVICE — LE PAIEMENT PAR LE CANAL MAISON

Fonction. Virement, carte, crédit : la banque produit **l'offre** de bout en bout, en produit maison.

Verrou créé — le paiement passe par le canal maison. Un virement ne s'initie que depuis l'application ou le site de la banque. Un marchand ou une plateforme ne peut pas **déclencher** l'ordre à la place du client.

- **Protège** : sécurité de bout en bout.
- **Empêche** : paiement initié par un tiers.
- Conséquence pratique : un e-commerçant doit soit rendre le virement manuel (saisie par le client), soit passer par la carte. Le virement n'est pas « utilisable comme un paiement ».

3 LE CANAL — L'INTEROPÉRABILITÉ IMPOSSIBLE

Fonction. Agence, web, application : la banque contrôle **l'accès** à 100 %. Chaque maillon renforce les autres.

Verrou créé — aucune interopérabilité entre banques. Chaque banque a ses formats, ses interfaces, ses règles. Une application qui veut lire plusieurs comptes doit **recoder** chaque intégration, une par une.

- **Protège** : autonomie d'évolution.
- **Empêche** : interopérabilité, économie de l'intégration.
- Coût du N×M : N applications × M banques = N×M intégrations à maintenir. C'est ce coût qui justifiera la standardisation (OBIE, Berlin Group), traitée en S3.

4 LE CLIENT — LA SÉCURITÉ PAR LE SECRET

Fonction. Le client a **un seul fournisseur pour tout** : il n'a aucune raison de sortir du périmètre.

Verrou créé — la sécurité repose sur le secret. Le seul mécanisme d'authentification est l'**identifiant + mot de passe**. Celui qui les connaît *est* le client : aucune délégation révocable, aucune traçabilité.

- **Protège** : simplicité apparente.
- **Empêche** : délégation révocable, traçabilité.
- Un secret partagé est un secret perdu. Prêter ses identifiants, c'est prêter sa signature — sans limite de durée, sans périmètre, sans moyen de reprendre la main.

À RETENIR

Un modèle *intégré* n'est pas un défaut de maturité : c'est un choix de structure. Sa force — la cohérence — est exactement ce qui rend l'entrée d'un tiers impossible.

CONSÉQUENCE

Le chaînon manquant, et le détour

Le client veut ce que le modèle ne permet pas. Alors il contourne. C'est ce contournement — l'accès par identifiants empruntés — qui rend le *screen scraping* inévitable.



Figure — faute de chaînon officiel, le tiers emprunte l'identité du client. C'est le contournement qui crée le risque, pas la demande du client.

ÉCONOMIE

La rente de verrouillage

Le modèle tient parce que changer de banque coûte plus cher que supporter sa banque. Ce n'est pas la qualité du service qui retient le client : c'est le coût de sortie.

Coût de sortie

Changer de compte, c'est reconstruire ses prélèvements, ses virements permanents, ses accès. Beaucoup de friction pour un bénéfice incertain.

Vue partielle

Le client ne voit qu'un fournisseur à la fois. Il ne peut pas comparer ce qu'il possède, donc il ne sait pas ce qu'il perd.

Cross-selling

La donnée de compte sert à proposer le produit suivant. Plus la relation est fermée, plus elle est rentable à exploiter.

Le vrai coût

Le verrouillage ne se paie pas en frais : il se paie en **immobilité**. Les banques savent que changer coûte cher, donc l'incitation à l'excellence baisse. C'est précisément l'argument de concurrence qui justifiera la DSP2.

SYNTHÈSE

Ce que le modèle protège, et ce qu'il empêche

PROPRIÉTÉ DU MODÈLE FERMÉ	CE QU'ELLE PROTÈGE	CE QU'ELLE EMPÊCHE
Donnée captive	Cohérence du SI, maîtrise du risque	Gestion de budget consolidée
Canal unique	Sécurité de bout en bout	Paiement initié par un tiers
Formats propriétaires	Autonomie d'évolution	Interopérabilité, économie de l'intégration
Secret partagé	**Simplicité apparente**	**Délégation révocable, traçabilité**

SÉQUENCE SUIVANTE

DSP1 · D'où l'on vient

Le modèle est décrit, ses limites posées. La première directive sur les services de paiement (2007) a tenté d'y répondre en construisant le marché unique — mais sans jamais toucher à l'accès aux comptes.

03 · DSP1 · D'OÙ L'ON VIENT

DSP1 - D'où l'on vient

PREMIÈRE RÉPONSE, INCOMPLÈTE

DSP1 - D'où l'on vient

En 2007, l'Europe crée le marché unique des paiements. C'est une vraie réussite — mais elle s'arrête au *paiement*. L'accès aux comptes, lui, reste hors du texte. Ce que la DSP1 n'a pas prévu, c'est exactement ce qui va poser problème huit ans plus tard.

IDENTITÉ

La fiche d'identité de la DSP1

ÉLÉMENT	VALEUR
Nom complet	Directive sur les services de paiement dans le marché intérieur (en anglais : *Payment Services Directive*, PSD)
Référence	Directive 2007/64/CE
Adoption	13 novembre 2007
Entrée en application	1er novembre 2009
Remplacée par	DSP2 — directive (UE) 2015/2366
Objet	**Construire un marché unique des paiements : harmoniser, agréer, abolir les frontières**

À RETENIR

La DSP1 est le socle de la DSP2. Tout ce que la DSP2 ajoute suppose le marché unique construit par la DSP1 — mais rien de ce qu'elle ajoute n'était prévu en 2007.

LE VRAI APPORT

Le « PSP » : une catégorie à la place d'un métier

L'apport conceptuel de la DSP1 n'est pas technique : c'est une **catégorie juridique**. Avant 2007, seuls les établissements de crédit pouvaient émettre des moyens de paiement. La DSP1 casse ce monopole en créant le

statut de *Prestataire de Services de Paiement* (PSP).



Cliquez sur une famille (1 à 3) : son exemple d'acteur et la façon dont le paiement circule.

1 ÉTABLISSEMENT DE CRÉDIT — LA BANQUE

La famille historique : elle existait *avant* la DSP1 et tient elle-même les comptes de ses clients.

- **Exemples** : BNP Paribas, Crédit Agricole, Revolut (licence bancaire).
- **Circulation** : virement ou carte, depuis le compte qu'elle tient elle-même.
- Peut fournir **tous** les services de paiement — c'est la famille la plus large.

2 ÉTABLISSEMENT DE PAIEMENT — LE PSP E-COMMERCE

La famille **créée** par la DSP1 : une non-banque agréée. C'est ici que se range ce qu'on appelle couramment le « PSP e-commerce ».

- **Exemples** : Stripe, Adyen, Payplug.
- **Circulation** : acquisition carte — encaisse pour le marchand, puis reverse sur son compte.
- **Avant 2007**, ce rôle n'était pas ouvert : il fallait une licence bancaire pour détenir les fonds d'un marchand. La DSP1 a rendu Stripe (2010) et Adyen (2006) possibles.
- Un **PISP** (créé par la DSP2) sera aussi un établissement de paiement — mais il initie un *virement*, pas une acquisition carte.

3 ÉTABLISSEMENT DE MONNAIE ÉLECTRONIQUE — LES WALLETS

Une famille au **régime assimilé** : elle émet de la monnaie électronique stockée sur un support (wallet, carte prépayée).

- **Exemples** : Lydia, Sumeria, cartes prépayées.
- **Circulation** : le client charge un solde, puis paie depuis ce solde.
- Complète le statut PSP sans être une banque ni un simple prestataire d'acquisition.

Pourquoi c'est décisif

Sans la notion de PSP, il n'y a pas de cadre pour agréer un non-banquier. Et sans cadre d'agrément, la DSP2 n'aurait pas pu inventer les AISP et les PISP — qui sont, juridiquement, des *PSP* de nouvelle espèce.

Le sigle recouvre deux niveaux

Dans le e-commerce, « PSP » désigne le prestataire qui encaisse pour un marchand sur son site. Dans la DSP1, c'est une **catégorie juridique**. Ce n'est pas une opposition : c'est un **rapport d'inclusion**. Un *statut large*, un *rôle étroit* : le PSP e-commerce n'est pas une catégorie concurrente, c'est un rôle *à l'intérieur* de la famille « établissement de paiement » du schéma ci-dessus.

Avant la DSP1, ce rôle n'était pas ouvert. Il fallait une licence bancaire pour détenir les fonds d'un marchand, et le règlement restait chez la banque acquéreuse. En créant le statut PSP, la directive de 2007 a rendu possibles des acteurs non bancaires — d'où Stripe (2010) et Adyen (2006), nés *grâce* à ce statut.

Ce que les exemples du schéma montrent. Stripe et Adyen sont des établissements de paiement : ils encaissent par carte pour un marchand. Un PISP (créé par la DSP2), lui, initie un *virement* depuis le compte du client chez sa banque. Deux façons différentes de faire passer un paiement, deux rôles différents au sein du même PSP.

LES APPORTS

Trois apports concrets

Le passeport européen

Une licence obtenue dans un État membre vaut dans les 27. Un établissement de paiement peut servir des clients partout dans l'EEE sans redemander une autorisation pays par pays.

La fin du réseau obligatoire

Virements et prélèvements SEPA ne passent plus nécessairement par les réseaux de cartes. Les frais interbancaires sont encadrés, les délais plafonnés.

La transparence tarifaire

Les frais doivent être connus avant l'opération. Fin des commissions cachées : le prix devient une information du contrat, pas une découverte.

Le bilan de la DSP1 est un succès de marché. Le SEPA devient un standard mondial, les paiements européens deviennent une commodité. Mais toute la valeur ajoutée créée reste *à l'intérieur* des canaux bancaires.

LIMITES

Trois angles morts

Ce que la DSP1 n'a pas fait n'est pas un oubli : en 2007, le problème ne se posait pas encore. Mais les trois angles morts vont devenir des verrous.



Figure — les trois angles morts de la DSP1. Chacun deviendra un chantier de la DSP2, et correspond à un verrou du modèle fermé.

ANGLE MORT DSP1	VERROU DU MODÈLE FERMÉ	RÉPONSE DSP2
Pas d'accès aux comptes	Donnée captive	Service AIS
Le tiers pour autrui non prévu	Canal de paiement unique	Service PIS
Authentification libre	**Sécurité par le secret**	**SCA obligatoire**

Le paysage européen sous la DSP1, en trois traits.

- **Un marché cloisonné.** Les banques traditionnelles sont seules à détenir les comptes et à fournir les services de paiement.
- **Des tiers en zone grise.** Les premiers agrégateurs de comptes et initiateurs de paiement existent, mais sans statut : ils opèrent par screen scraping ou par partage de codes d'accès.
- **Un cadre qui ne concerne que les paiements.** La DSP1 n'ouvre pas l'accès aux tiers. Elle pose un cadre juridique homogène pour régir les paiements traditionnels — virements, prélèvements, cartes — à l'échelle européenne.

Ce que ça donne en pratique

Trois situations ordinaires de 2009. Aucune n'est illégale, et aucune n'a de cadre.

1 · Lire ses comptes

Un client a un compte chez trois banques. Il veut une seule vue d'ensemble. Aucun texte ne prévoit qu'une application puisse lire les comptes pour lui : la banque n'a aucune obligation d'ouvrir l'accès, et aucun agrément ne couvre cette lecture.

Résultat : l'application demande les identifiants du client et se connecte à sa place. C'est le screen scraping.

2 · Payer depuis son compte

Un site marchand accepte la carte, pas le virement. Or le client veut payer depuis son compte. Aucun tiers ne peut déclencher un virement *au nom du client* depuis son compte bancaire : ce rôle n'existe pas en 2009.

Résultat : le client doit quitter le site, ouvrir son application bancaire, recopier l'IBAN du bénéficiaire et valider. Une faute de frappe et le virement part au mauvais destinataire. Beaucoup abandonnent en cours de route et paient par carte.

3 · Sécuriser l'accès

Un client partage son mot de passe avec un agrégateur. La DSP1 n'impose aucune méthode d'authentification : le mot de passe seul suffit, et le secret partagé devient la norme.

Résultat : impossible de révoquer l'accès d'un tiers sans changer son mot de passe partout.

Le fil commun de ces trois cas. Dans chacun, le client veut faire quelque chose de légitime avec son propre compte, et le droit ne prévoit pas comment. La DSP2 ne créera pas de nouveaux usages : elle donnera un cadre à ceux qui existent déjà.

CONSÉQUENCE

Le vide juridique, et ce qu'il a laissé faire

Entre 2009 et 2015, les usages numériques explosent plus vite que le droit. Des applications veulent lire les

comptes et déclencher des paiements — et rien ne l'interdit, mais rien ne l'encadre.



Figure — huit ans entre les deux directives. Le vide juridique n'a pas empêché les usages : il les a laissés se développer sans garde-fou.

Le paradoxe de la DSP1

La DSP1 a réussi son objectif : rendre le paiement européen fluide et peu coûteux. Mais elle a laissé dehors la question qui allait devenir centrale — **qui a le droit de lire le compte pour le compte du client ?**

C'est précisément cette question que traite la DSP2, et c'est le point de départ du récit de Lyam.

SYNTHÈSE

Ce que la DSP1 lègue à la DSP2

Ce qu'elle a construit

- La notion de **PSP** : agréer sans être une banque.
- Le **passeport européen** : une licence pour 27 pays.
- Le **SEPA** : virement et prélèvement comme commodités.
- La **transparence** : les frais avant l'opération.

Ce qu'elle a laissé ouvert

- L'accès aux comptes par un tiers : **non prévu**.
- Les services d'initiation et d'information : **inexistants**.
- L'authentification forte : **non imposée**.
- Le consentement révocable : **hors champ**.

SÉQUENCE SUIVANTE

La DSP2 en fiche

Huit ans après, la directive (UE) 2015/2366 vient combler les trois angles morts. Sa fiche d'identité donne le décor complet avant d'en dérouler les mécanismes.

04 · LA DSP2 EN FICHE

La DSP2 en fiche

LA CARTE D'IDENTITÉ DE LA DIRECTIVE

Le cadre

Avant de suivre Lyam et de dessiner une architecture, posons froidement le cadre : qu'est-ce que la DSP2, où s'applique-t-elle, quels services couvre-t-elle, et quelles obligations impose-t-elle ?

IDENTITÉ

Carte d'identité de la DSP2

ÉLÉMENT	VALEUR
Nom complet	Deuxième directive sur les services de paiement (en anglais : *Payment Services Directive 2*, PSD2)
Référence	Directive (UE) 2015/2366
Adoption	25 novembre 2015
Remplace	DSP1 — directive 2007/64/CE
Type	Directive : à transposer en droit national par chaque État membre
Objet	**Étendre les services de paiement, sécuriser l'authentification, ouvrir l'accès aux comptes**

À RETENIR

La DSP2 n'est pas un règlement : c'est une directive. Chaque pays la transpose dans sa loi, ce qui explique des nuances d'application d'un État à l'autre.

CALENDRIER — LES GRANDES DATES D'APPLICATION

Une directive ne s'applique pas du jour de sa publication : il faut la transposer, puis laisser aux acteurs le temps de se mettre en conformité.

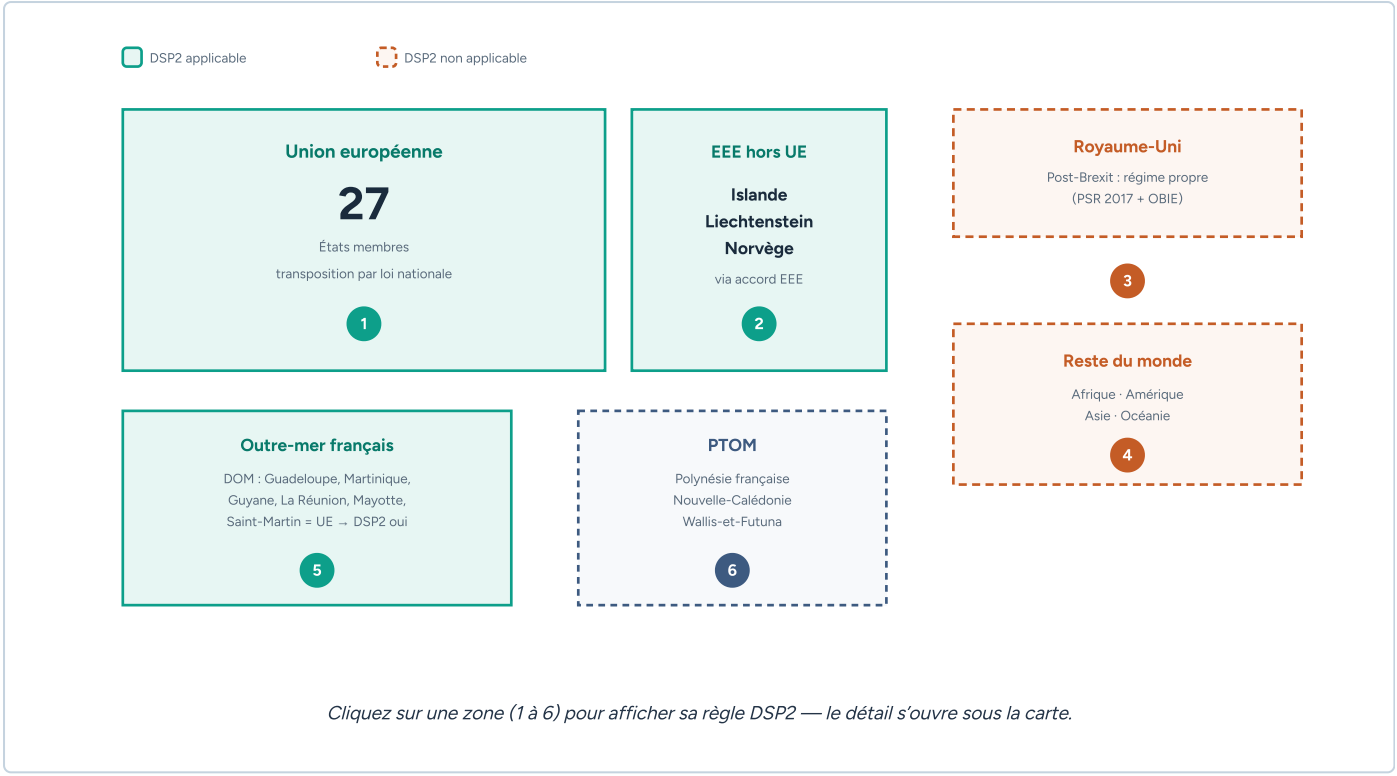
DATE	ÉTAPE	EN FRANCE
2007	DSP1 adoptée	Transposition en droit français
25 nov. 2015	DSP2 adoptée	—
9 août 2017	Transposition	Ordonnance n° 2017-1252
13 janv. 2018	Application	Services AIS / PIS en vigueur
14 sept. 2019	**RTS SCA & communication sécurisée**	**Authentification forte généralisée**

Et après ? La DSP2 continue d'évoluer : révision « DSP3 » et règlement FIDA (accès aux données financières) prolongent la logique d'ouverture au-delà des seuls comptes de paiement — on y reviendra en fin de module.

CHAMP D'APPLICATION

Où la DSP2 s'applique-t-elle ?

La directive s'applique dans l'**Espace économique européen (EEE)** : les 27 États membres de l'Union européenne, plus l'**Islande, le Liechtenstein et la Norvège**. Elle s'applique lorsque le prestataire de services de paiement (banque ou tiers) *et* l'autre partie sont établis dans l'EEE, ou que l'opération concerne une seule partie de l'EEE.



Cliquez sur une zone (1 à 6) pour afficher sa règle DSP2 — le détail s'ouvre sous la carte.

1 UNION EUROPÉENNE — 27 ÉTATS MEMBRES

La DSP2 est une **directive** : chaque État membre l'a transposée dans sa loi nationale (en France, ordonnance n° 2017-1252 du 9 août 2017). Elle **s'applique** dans les 27 pays de l'UE, avec de légères nuances d'un État à l'autre.

- Principe du **passeport** : une autorisation obtenue dans un État vaut dans les 27.
- Transposition nationale, puis application depuis le 13 janvier 2018.

2 EEE HORS UE — ISLANDE, LIECHTENSTEIN, NORVÈGE

Via l'**accord EEE**, ces trois pays appliquent la DSP2 comme les États membres : la directive **s'y applique**. Ils complètent le périmètre de l'Espace économique européen.

- Islande, Liechtenstein et Norvège : mêmes règles que l'UE.
- Soit **30 États** au total dans l'EEE.

3 ROYAUME-UNI — HORS EEE DEPUIS LE BREXIT

Depuis le Brexit, le Royaume-Uni **n'est plus dans l'EEE** : la DSP2 n'y est **pas applicable** en tant que telle. Le pays a conservé un régime voisin (les *Payment Services Regulations 2017*) et son propre standard Open Banking (OBIE).

- Un TPP britannique qui accède à une banque de l'EEE relève d'une autre logique.

4 RESTE DU MONDE — AFRIQUE, AMÉRIQUE, ASIE, OCÉANIE

La DSP2 **ne s'applique pas** en Afrique, ni en Asie, ni en Amérique, ni dans les autres régions hors EEE. Elle est un texte européen : chaque pays a ses propres régulateurs (BCEAO/UMOA en zone franc CFA, BEAC/CEMAC, Bank Al-Maghrib…).

- **Exception** : un opérateur africain qui fournit des services de paiement *dans* l'EEE entre dans le périmètre DSP2 pour cette activité.

5 OUTRE-MER FRANÇAIS (DOM) — DSP2 APPLICABLE

Les 5 régions d'outre-mer (Guadeloupe, Martinique, Guyane, La Réunion, Mayotte) et Saint-Martin font partie de l'UE, donc de l'EEE : **la DSP2 s'y applique**.

6 PTOM — DSP2 NON APPLICABLE

Les pays et territoires d'outre-mer (Polynésie française, Nouvelle-Calédonie, Wallis-et-Futuna…) sont **hors UE/EEE** : la DSP2 **n'y est pas applicable**.

PÉRIMÈTRE MATÉRIEL

Ce que la DSP2 couvre — et ce qu'elle ne couvre pas

La DSP2 est une directive « services de paiement » : elle couvre tout ce qui touche à l'exécution d'un paiement et à l'accès aux comptes de paiement. Les trois services AIS, PIS et CBPII sont ceux qui ouvrent la voie à l'Open Banking (rôles détaillés en S2).

Couvert par la DSP2

- Virements et prélèvements libellés en euro ou en devise de l'EEE
- Paiements par carte (dans certaines dispositions)
- Services d'accès aux comptes (AIS)
- Services d'initiation de paiement (PIS)
- Confirmation de disponibilité de fonds (CBPII)

Hors champ de la DSP2

- Opérations en espèces entre particuliers (hors professionnel)
- Certains paiements intra-groupe ou à titre gratuit
- Paiements scripturaux sur papier
- Opérations de change pur, sans service de paiement
- Cartes « fermées » limitées à un réseau de biens/services

OBLIGATIONS

Les grandes obligations, par acteur

La DSP2 ne dit pas seulement « ouvrez » : elle répartit des obligations précises entre la banque (ASPSP), le tiers (TPP) et les autorités. Voici les principales, sans le détail des rôles (traité en S2).

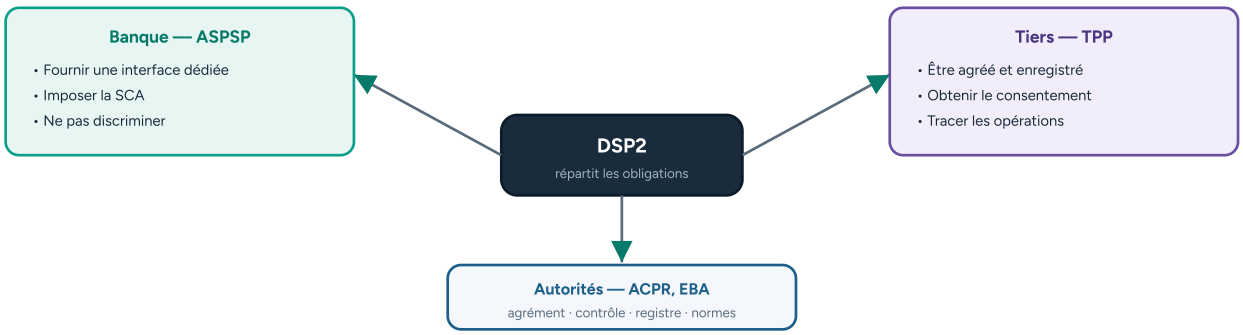


Figure — la DSP2 répartit les obligations entre la banque, le tiers agréé et les autorités de supervision.

OBLIGATION	QUI	EN BREF
Interface dédiée	Banque (ASPSP)	Fournir une API aux tiers agréés, gratuite et sans obstacle
Agrément & enregistrement	Tiers (TPP)	Être agréé par l'autorité nationale et inscrit au registre
Consentement explicite	Banque + tiers	Le client autorise l'accès, peut le révoquer à tout moment
Authentification forte (SCA)	Banque	Deux facteurs indépendants pour authentifier le client
Non-répudiation & journalisation	Banque + tiers	Prouver qui a fait quoi et quand
Répartition des responsabilités	Tous	Qui rembourse en cas d'incident (fraude, erreur, usurpation)
Supervision	**Autorités (ACPR, EBA)**	**Agrément, contrôle, registre central, normes techniques**

Une exigence en filigrane : la non-discrimination

Une banque ne peut pas traiter différemment une opération selon qu'elle est initiée par le client ou par un TPP agréé. C'est une des garanties qui rend l'ouverture effective — et non théorique.

CLIN D'ŒIL

De la DSP1 à la DSP2 : ce qui change

La DSP1 (2007/64/CE) avait créé le marché unique des paiements. La DSP2 le prolonge en y intégrant les acteurs nés de l'économie numérique.

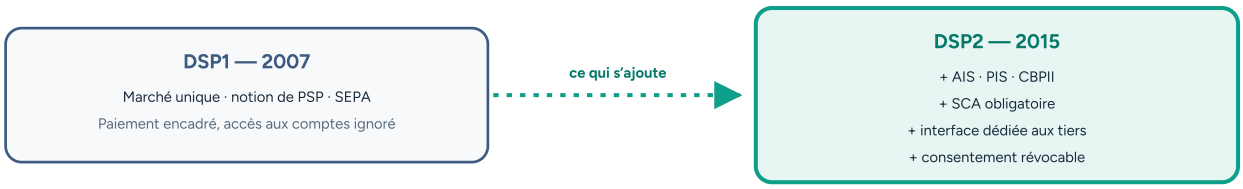


Figure — la DSP2 prolonge la DSP1 : trois nouveaux services, la SCA et l'interface dédiée s'ajoutent au socle de 2007.

QUESTION	DSP1	DSP2
Comment un tiers lit-il un compte ?	Pas prévu	API dédiée, avec consentement
Comment un tiers déclenche-t-il un paiement ?	Pas prévu	Service PIS agréé
Comment le client s'authentifie-t-il ?	Libre (souvent mot de passe)	Authentification forte (SCA)
Qui peut accéder aux comptes ?	**La banque seule**	**La banque + tiers agréés autorisés**

En une phrase. La DSP1 a organisé le *paiement* ; la DSP2 organise l'*accès* et le *partage*. C'est ce déplacement qui ouvre l'ère de l'Open Banking.

SÉQUENCE SUIVANTE

Qui écrit la règle ?

On sait ce qu'est la DSP2, où elle s'applique, ce qu'elle couvre et ce qu'elle impose. Reste à savoir **qui** l'a écrite, qui la précise et qui la fait appliquer : direction les autorités européennes.

05 · LES AUTORITÉS EUROPÉENNES

Les autorités européennes

QUI ÉCRIT LA RÈGLE, QUI LA PRÉCISE, QUI LA FAIT APPLIQUER

Les autorités européennes

La DSP2 n'est pas tombée du ciel. Elle est le produit d'un processus à trois étages : la *décision politique*, la *traduction technique* et la *supervision*. Chaque étage a ses institutions — et certaines ont joué un rôle décisif bien avant 2015.

LE PRINCIPE

Trois étages, pas une institution unique

Une confusion fréquente : « c'est Bruxelles qui décide tout ». En réalité, l'EBA a traduit politiquement le texte en normes techniques opposables, et les superviseurs nationaux agréent au quotidien.



La directive fixe le cadre ; la norme technique le rend applicable ; le superviseur l'applique au terrain.

Cliquez sur un étage (1 à 3) pour comparer ses acteurs en DSP1 (2007) et DSP2 (2015).

1 ÉTAGE 1 · POLITIQUE — COMMISSION, PARLEMENT, CONSEIL

C'est l'étage qui **écrit la directive**. La Commission propose, le Parlement et le Conseil amendent et adoptent en codécision (trilogue). Le schéma institutionnel ne change pas entre les deux directives : seuls les textes et les compromis diffèrent.

- **Commission** (DG FISMA) : propose la DSP1 en 2005, puis la révision DSP2 en 2013. Adopte ensuite les actes délégués (dont les RTS de l'EBA).
- **Parlement** (commission ECON) & **Conseil** (ECOFIN) : co-législateurs. Le Parlement pousse la transparence tarifaire et l'ouverture ; le Conseil porte les intérêts bancaires nationaux.
- **En DSP2**, c'est le trilogue de 2015 qui produit la version finale : les trois nouveaux services (AIS/PIS/CBPII) y sont consacrés.

2 ÉTAGE 2 · TECHNIQUE — L'EBA (ET LE CEBS AVANT ELLE)

C'est l'étage qui **transforme un article en norme applicable**. Changement majeur entre les deux directives : en 2007, l'EBA **n'existe pas** (créée en 2011) ; c'est le **CEBS**, simple comité consultatif, qui conseille les législateurs, sans pouvoir normatif.

- **DSP1 (2007)** — CEBS : avis et recommandations non contraignants. Il ne peut pas édicter de normes techniques.
- **DSP2 (2015)** — EBA : rôle décisif. RTS SCA & CSC (règlement délégué 2018/389), orientations sur les interfaces dédiées, registre central des PSP agréés.
- En 2011, l'EBA **absorbe le CEBS** et gagne le pouvoir normatif que son prédécesseur n'avait pas.

3 ÉTAGE 3 · SUPERVISION — AUTORITÉS NATIONALES & BCE

C'est l'étage qui **applique au terrain**. L'**ACPR** (en France), la Bafin, la DNB ou la FCA agréent les prestataires et les contrôlent ; la **BCE** intervient en arrière-plan sur le prudentiel et les paiements.

- **Autorités nationales** : transposition, agrément des TPP, registre national, contrôles et sanctions.
- **BCE** : avis sur les paiements et les risques ; supervision prudentielle des grandes banques (MUS). À ne pas confondre avec l'EBA.
- La répartition national/prudentiel ne change pas fondamentalement entre DSP1 et DSP2 : c'est l'intensité du contrôle des TPP qui monte.

À RETENIR

Ne jamais mélanger *qui écrit* et *qui applique*. L'EBA écrit les RTS ; l'ACPR agrée et contrôle. Les deux sont indispensables, mais sur le terrain, ce n'est pas la même personne à qui vous vous adressez.

FOCUS EBA

Pourquoi l'EBA est l'autorité centrale

La DSP2 renvoie **explicitement** à l'EBA une dizaine de fois. Ce n'est pas un hasard : la directive pose le principe, l'EBA écrit le mode d'emploi.

Trois productions qui changent tout

- **RTS SCA & CSC** (règlement délégué 2018/389) : ce qui compte comme authentification forte, les exemptions, la communication sécurisée entre ASPSP et TPP. Adopté par la Commission sur proposition de l'EBA.
- **Orientations** (guidelines) : interprétation des obstacles à l'accès, des interfaces dédiées, des parcours de redirection. Non contraignantes en théorie, applicables en pratique.
- **Registre central** des PSP agréés : l'annuaire officiel des TPP. Sans lui, aucune banque ne peut vérifier qu'un TPP est bien agréé — composant de sécurité traité en S3.

Le piège classique

Beaucoup assimilent « EBA » et « BCE ». Ce sont deux institutions distinctes : l'EBA est une **autorité de supervision bancaire** qui écrit des normes ; la BCE est la **banque centrale de la zone euro** qui mène la politique monétaire et supervise les grandes banques. Les deux ne sont pas interchangeables.

ÉCOSYSTÈME

Les autres acteurs qui comptent

Au-delà du quatuor central, plusieurs institutions interviennent sur des terrains adjacents : protection des données, concurrence, normalisation technique.

INSTITUTION	RÔLE POUR LA DSP2	LIEN AVEC LE COURS
CEPD / EDPB	Comité européen de la protection des données	Articulation DSP2 / RGPD — consentement & finalité
ESMA	Autorité européenne des marchés financiers	Sujets de transparence et d'investissement
EIOPA	Autorité européenne des assurances et pensions	Périphérique pour la DSP2, utile pour l'Open Finance
ACPR + Banque de France	**Agrément et supervision des PSP en France**	**Registre national, contrôles, sanctions — S2 et S4**
Berlin Group / OBIE	Organismes de standardisation technique (non publics)	Standards d'API, S3

Les trois autorités européennes de supervision (ESA)

L'**EBA**, l'**ESMA** et l'**EIOPA** forment le trio des *European Supervisory Authorities*. Elles partagent un comité conjoint pour les sujets transverses. C'est ce trio qui portera une grande partie de la future **DSP3** et de l'*Open Finance* (J5).

SYNTHÈSE

Qui a fait quoi, en un tableau

INSTITUTION	DSP1 (2007)	DSP2 (2015)
Commission	Propose le texte	Propose la révision (2013) et adopte les RTS
Parlement + Conseil	Co-législateurs (trilogue)	Co-législateurs (trilogue 2015)
CEBS (précurseur)	Avis consultatifs	—
EBA	**— (créée en 2011)**	**RTS, orientations, registre central — rôle central**
BCE	Avis sur les paiements	Avis + supervision prudentielle
ACPR / nationales	Transposition & agrément	Agrément TPP, registre national, contrôles

SÉQUENCE SUIVANTE

Et hors d'Europe ?

Le cadre européen est clair : ce que la DSP1 n'avait pas prévu, ce que la DSP2 a ajouté, et qui l'a fait. Mais l'Europe n'est pas seule à ouvrir les comptes : prenons un peu de recul pour comparer avec le reste du monde.

L'Open Banking hors d'Europe

LE MÊME MOUVEMENT, AILLEURS DANS LE MONDE

L'Open Banking hors d'Europe

La DSP2 n'a pas inventé l'ouverture des comptes. D'autres pays l'ont fait avant, après, ou autrement — et parfois avec des modèles plus ambitieux. Ce détour par le monde sert à situer la DSP2 : ni première, ni dernière, mais **la plus structurée**.

LE CONSTAT

La DSP2 est la première à légiférer — mais la plus lente à appliquer

La DSP2 est **la première à promulguer** un cadre d'accès aux comptes : 2015, avant tous les autres. Mais elle est aussi **la plus lente à appliquer** : les services TPP n'entrent en vigueur qu'en janvier 2018, la SCA en septembre 2019. Le Royaume-Uni (2017) et le Mexique (2018) publient leur cadre avant elle. L'avance européenne est donc celle du *texte*, pas celle du *terrain*.

À RETENIR

La DSP2 est première en date de promulgation, pas en date d'effet. Chacun a ensuite choisi sa voie : l'Europe légifère par directive ; le Royaume-Uni impose par l'autorité de concurrence ; l'Australie légifère sur la donnée avant la banque ; l'Inde construit une infrastructure publique.

CHRONOLOGIE

Qui a promulgué quoi, et quand

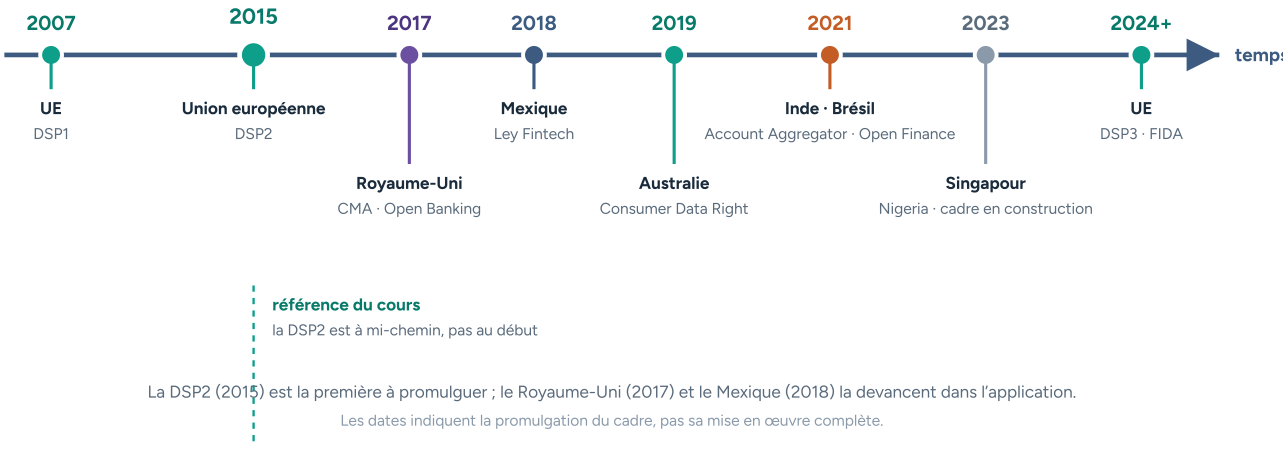


Figure — l'Open Banking dans le monde. La DSP2 est adoptée en 2015, avant tous les autres. Le Royaume-Uni et le Mexique publient leur cadre avant qu'elle ne s'applique (2018).

COMPARATIF

Cinq modèles, cinq logiques

Le tableau ci-dessous donne la date de promulgation et le texte de référence. Les dates doivent être vérifiées en séance : certaines sont des dates d'entrée en vigueur, d'autres des dates d'adoption.

ZONE	TEXTE OU INITIATIVE	DATE	LOGIQUE
Union européenne	DSP2 — directive (UE) 2015/2366	2015	Directive : accès aux comptes par tiers agréés
Royaume-Uni	CMA Retail Banking Market Investigation Order · Open Banking Ltd	2017	Remède de concurrence, imposé aux 9 grandes banques
Mexique	Ley Fintech (Ley para Regular las Instituciones de Tecnología Financiera)	2018	Loi fintech, API ouvertes en trois niveaux de données
Australie	Consumer Data Right (CDR) · Treasury Laws Amendment	2019	Droit à la donnée *avant* la banque : applicable à tout secteur
Inde	**RBI Account Aggregator Framework**	**2021**	**Infrastructure publique : agrégateurs de données sous licence**
Brésil	Open Banking / Open Finance (Banco Central do Brasil)	2021	Phasage progressif : données, puis paiements, puis autres produits
Singapour	MAS — API Exchange (APIX) et directives Open Banking	2021–2023	Approche coopérative, volontaire puis encadrée
Hong Kong	HKMA Open API Framework	2018	Cadre en quatre phases, piloté par le régulateur
Nigeria	Open Banking Framework (CBN)	2021–2023	Cadre opérationnel, mise en œuvre progressive

Prudence sur les dates

Les dates varient selon la source : adoption du texte, publication au journal officiel, entrée en vigueur, ou première obligation effective. Pour un exposé, toujours citer **la nature de la date** — sinon le débat porte sur la chronologie au lieu du contenu. Les valeurs ci-dessus sont à recouper avec les textes officiels avant usage.

LECTURE

Quatre façons d'ouvrir les comptes

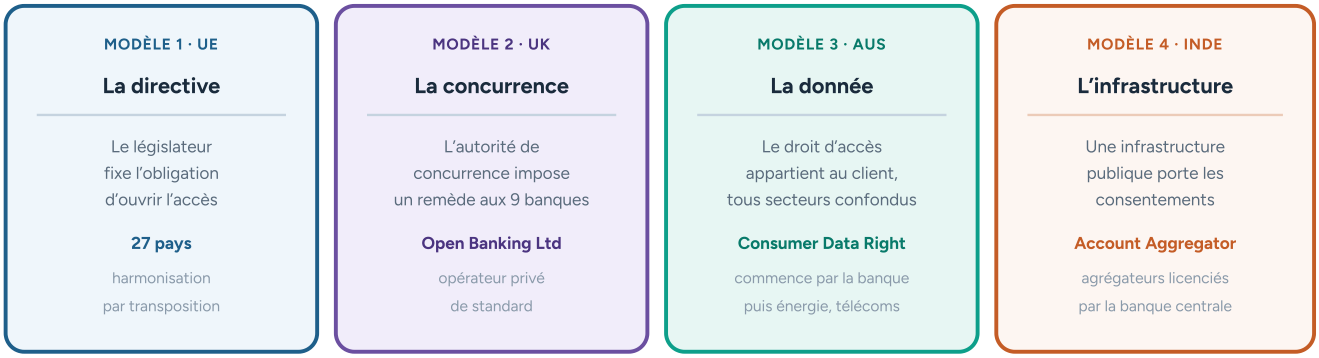


Figure — quatre logiques d'ouverture : la loi (UE), la concurrence (UK), le droit du client (Australie), l'infrastructure publique (Inde).

Ce que la DSP2 a de spécifique

- **Une portée de marché** : 27 pays, une seule règle.
- **Une articulation** explicite avec le RGPD.
- **Trois services** juridiquement définis (AIS, PIS, CBPII).
- **Une authentification forte** imposée par norme technique.

Ce que d'autres font autrement

- **Le Royaume-Uni** passe par la concurrence, pas par la loi.
- **L'Australie** raisonne « droit à la donnée », pas « services de paiement ».
- **L'Inde** construit une infrastructure publique de consentement.
- **Le Brésil** élargit dès le départ à l'*Open Finance* (assurance, investissement).

SANS TEXTE CADRE

Et quand il n'y a pas de loi ?

La majorité des ouvertures se font *sans* texte dédié. Ce n'est pas « les acteurs qui légifèrent » — personne ne légifère en dehors du législateur. Les acteurs **s'auto-encadrent**, et le régulateur entérine ensuite.

MÉCANISME	QUI FIXE LA RÈGLE	EXEMPLE
Contrat privé	Deux acteurs qui signent	États-Unis : Plaid et les banques
Standard d'industrie	Un collectif d'acteurs	Allemagne : FinTS
Ligne directrice	**Le régulateur, sans base légale**	**Singapour : MAS**

L'absence de loi n'est pas neutre

Sans texte cadre, l'ouverture existe — mais son rythme dépend du **rapport de force entre acteurs**. Aux États-Unis, le droit d'accès est inscrit dans le Dodd-Frank depuis 2010, sans être précisé avant 2024 : pendant quatorze ans, ce sont les contrats privés qui ont structuré le marché.

SYNTHÈSE

Ce que ce détour apporte au cours

Trois enseignements

1. L'Europe a promulgué la première, mais l'a appliqué plus tard que d'autres : son avance est juridique, pas opérationnelle. **2.** Le modèle européen n'est pas le plus ambitieux : le Brésil et l'Inde vont plus loin sur la donnée. **3.** Les standards techniques se ressemblent partout (OAuth2, consentement, API) parce que les contraintes sont les mêmes.

SÉQUENCE SUIVANTE

Le décor est posé — place à l'histoire

On sait ce qu'est la DSP2, où elle s'applique, ce qu'elle couvre et ce qu'elle impose. La S1 raconte maintenant **pourquoi** tout cela est devenu nécessaire, à travers le quotidien de Lyam.

07 · S1 · LE PROBLÈME

S1 · Le problème

LE MONDE D'AVANT LA DSP2

Le problème

Avant de comprendre la solution, il faut comprendre ce qui ne marchait pas. Cette séquence suit un client, Lyam, puis remonte au cadre réglementaire qui a rendu la DSP2 nécessaire.

FIL ROUGE **Lyam, 28 ans**, chef de projet. Deux comptes : un compte courant dans une banque traditionnelle, « Banque Est », et un compte dans une néobanque. Il veut simplement *voir tout son argent au même endroit*.

RÉCIT · 2017

Lyam installe une application de budget

Lyam télécharge *MonBuddy*, une application qui promet de « ranger vos dépenses, sans effort ». Pour fonctionner, il lui demande trois choses : son nom, son numéro de téléphone… et **ses identifiants de banque en ligne**.

Lyam hésite deux secondes, lit les conditions (cinq lignes minuscules), clique sur « Accepter ». L'application fonctionne : toutes ses dépenses apparaissent, classées par catégorie. Il est ravi.

Ce que Lyam ne voit pas, c'est l'envers du décor. Et cet envers du décor est précisément ce qui a rendu la DSP2 nécessaire.

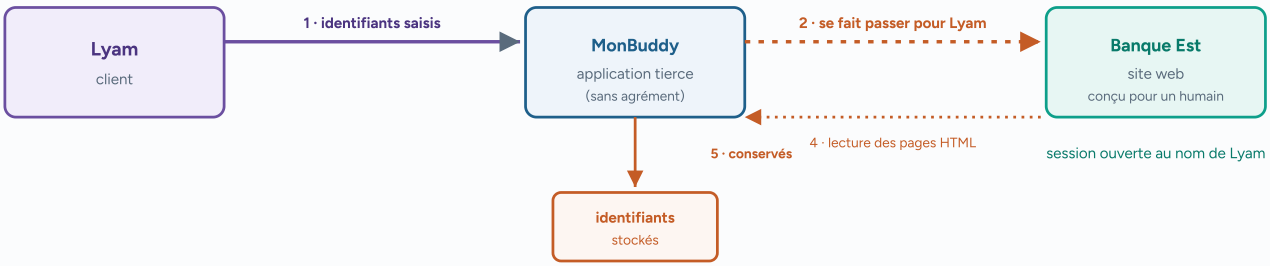
CE QUE LYAM CROIT	CE QUI SE PASSE RÉELLEMENT
« MonBuddy se connecte à ma banque, comme n'importe quelle appli. »	MonBuddy ne « se connecte » pas : elle se **fait passer pour Lyam**. Elle utilise ses identifiants pour ouvrir sa vraie session bancaire — et les conserve.

RÉCIT · LE MÉCANISME

Le « screen scraping » : entrer par la porte du client

Le site de Banque Est est conçu pour un humain : une page de connexion, un clic, un tableau de bord. MonBuddy ne peut pas « parler » à la banque autrement : elle simule un navigateur, remplit le formulaire et *lit les pages* à la place de Lyam.

Le screen scraping en trois acteurs



1 **Rejouer la connexion**

MonBuddy envoie les identifiants de Lyam au site de Banque Est, comme le ferait son navigateur. Aucune règle ne l'arrête : la banque ne fait pas la différence.

2 **Lire les pages**

Une fois la session ouverte, MonBuddy parcourt les pages HTML du compte et *extrait* les montants et les libellés en s'appuyant sur la structure de la page.

3 **Répéter, encore et encore**

Dès qu'un montant change, il faut relancer tout le processus. Des milliers de connexions automatisées par jour, qui ressemblent à des connexions humaines.

4 **Stocker les identifiants**

Pour pouvoir se reconnecter demain, MonBuddy conserve les identifiants de Lyam. C'est là que tout devient grave.

Trois problèmes pour le prix d'un

Pour Lyam : si MonBuddy est piratée, ses identifiants bancaires le sont aussi. Et en cas de fraude, la banque peut refuser de rembourser : le client a lui-même communiqué ses codes.

Pour Banque Est : des centaines de connexions automatisées par jour, des coûts d'infrastructure sans contrepartie, et aucune visibilité sur qui accède réellement.

Pour MonBuddy : une activité juridiquement précaire, dépendante du bon vouloir — et de la stabilité — de chaque interface bancaire.

REVENIR À L'ESSENTIEL DU COURS — LE SCREEN SCRAPING

Le **screen scraping** consiste à automatiser l'interface web d'une banque pour en extraire les données. C'est un accès *indirect* : le tiers ne dispose d'aucun contrat avec l'établissement, ne s'identifie pas auprès de lui, et agit sous l'identité du client.

On parle d'accès indirect pour l'opposer à l' **accès direct** par API dédiée, que la DSP2 rendra obligatoire à partir de 2018–2019.

RÉCIT · L'INCIDENT

Le jour où Lyam a compris

Un matin, Lyam reçoit un SMS de sa banque : « Paiement suspect de 900 € sur votre compte. Confirmez-vous cette opération ? » Il n'y est pour rien. La banque gèle la carte, ouvre une procédure. On lui demande alors : « Avez-vous communiqué vos identifiants à un tiers ? »

Lyam répond oui. La banque lui explique qu'il devra porter une partie du préjudice : en communiquant ses codes, il a lui-même levé la protection. Ce jour-là, Lyam désinstalle MonBuddy. Et perd l'usage qu'il aimait.

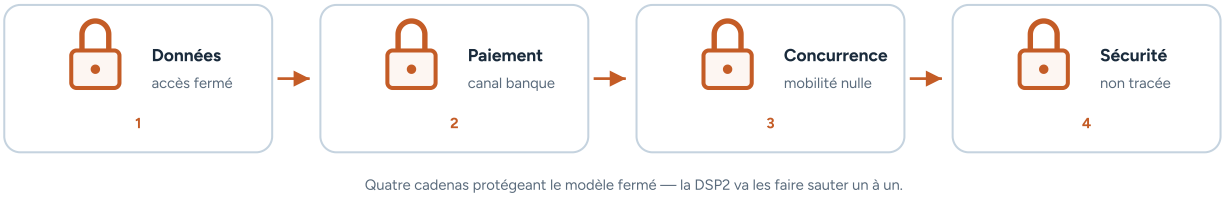
Ce que révèle ce cas

Le problème n'est pas que Lyam voulait voir ses comptes : *c'est légitime*. Le problème est qu'il n'avait aucun moyen **sûr** de le faire. Ni lui, ni la banque, ni l'application n'avaient de cadre pour organiser proprement un accès délégué.

ANALYSE

Les quatre verrous, vus par Lyam

Derrière l'histoire de Lyam, il y a quatre verrous structurels. Ils ne sont pas techniques par hasard : ils protégeaient le modèle économique de la banque.



Quatre cadenas protégeant le modèle fermé — la DSP2 va les faire sauter un à un.

Figure — les quatre verrous qui empêchaient l'accès délégué avant la DSP2.

Verrou sur les données

> *Lyam n'a aucun moyen officiel de partager ses comptes avec une application qui lui plaît.*

La banque détient la donnée et la sert uniquement à son propre canal. Pas d'API pour un tiers : aucun concurrent ne peut construire par-dessus le compte.

> **COURS**
>
> La donnée de compte est l'actif stratégique de la banque : son verrouillage protège la relation client et le cross-selling. Conséquence : aucune application tierce ne peut proposer une gestion de budget consolidée sans emprunter les identifiants.

2

Verrou sur le paiement

> *Lyam paie chez un marchand : par carte, ou en saisissant lui-même un virement. Rien d'autre.*

Payer depuis son compte suppose de passer par le canal de la banque. Aucun tiers agréé ne peut déclencher un virement au nom du client.

> **COURS**
>
> Le contrôle de l'initiation de paiement garantit les revenus d'interchange et de frais de tenue de compte. Le commerçant reste dépendant des réseaux de cartes et de leurs commissions.

3

Verrou sur la concurrence

> *Lyam veut comparer Banque Est et sa néobanque : impossible autrement qu'à la main, capture d'écran par capture d'écran.*

Chaque banque verrouille son expérience. Un client qui change de banque doit reconstruire ses habitudes et abandonner ses historiques.

> **COURS**
>
> La mobilité bancaire reste faible : la concurrence joue sur le produit (taux, frais), pas sur le service numérique ouvert. Un client qui part perd ses habitudes d'interface et la continuité de ses historiques.

4

Verrou sur la sécurité

> *Quand Lyam partage ses identifiants, personne ne peut dire qui a accédé à son compte, ni pour faire quoi.*

L'authentification et la gestion des accès sont propres à chaque banque, sans délégation tracée. En cas d'incident, tout le monde se renvoie la responsabilité.

> **COURS**
>
> L'absence de délégation formalisée empêche toute réversibilité : révoquer un accès revient littéralement à changer ses codes. Les incidents (fraude, accès non autorisé) sont imputables à des tiers, sans obligation de transparence pour le client.

CONTEXTE RÉGLEMENTAIRE

Pourquoi la DSP1 n'avait pas suffi

La première directive sur les services de paiement (DSP1, directive 2007/64/CE) a créé le **marché unique des paiements** dans l'Union européenne : elle a introduit la notion de *prestataire de services de paiement (PSP)*, supprimé l'obligation de passer par les réseaux de cartes pour les virements et prélèvements SEPA, et encadré les frais et délais entre les établissements.

Mais elle raisonnait dans un monde où le paiement passait exclusivement par les canaux de la banque du client. Entre 2007 et 2015, l'usage a changé de nature : agrégateurs, prestataires techniques de paiement, applications qui manipulent les données bancaires. Or ces usages reposaient sur une pratique juridiquement fragile — l'accès indirect par identifiants — que le droit ne reconnaissait pas.

JALON	DATE	CE QUI CHANGE
DSP1	2007	Marché unique, notion de PSP, SEPA
Publication DSP2	25 nov. 2015	Nouveaux services, SCA, accès aux comptes
Transposition FR	9 août 2017	Ordonnance 2017-1252
Entrée en application	13 janv. 2018	Services d'accès et d'initiation
RTS SCA / CSM	**14 sept. 2019**	**Authentification forte généralisée**

Le diagnostic tient en une phrase. Avant la DSP2, il était possible de consulter et de déclencher un paiement depuis des tiers — mais uniquement en spoliant l'identité numérique du client. La directive va rendre cet usage lisible, explicite et sûr.

ACTE FONDATEUR

La DSP2, et son articulation avec le RGPD

> La **directive (UE) 2015/2366**, dite « **DSP2** » (Revised Payment Services Directive), adoptée le **25 novembre 2015**, **remplace et étend** la DSP1 (2007/64/CE). Elle introduit trois catégories de services de paiement supplémentaires, impose l'**Strong Customer Authentication** (SCA) et interdit le *screen scraping* au profit d'interfaces dédiées.

La DSP2 ouvre l'accès aux données bancaires, mais elle ne dispense pas du **RGPD**. Les deux textes se superposent : la DSP2 fixe le *canal* (interface dédiée, consentement, SCA), le RGPD fixe le *cadre du traitement* (finalité, minimisation, durée, droits).

Ce que la DSP2 apporte

- Un droit d'accès aux comptes via un TPP agréé
- Une obligation d'interface dédiée pour l'ASPSP
- Un consentement explicite et révocable
- Des limites de durée d'accès (typiquement 90 jours)

Ce que le RGPD ajoute

- Une base légale et une finalité claire
- Un principe de minimisation des données
- Des droits (accès, rectification, effacement)
- Une accountability : DPO, registre, DPIA

Conséquence pratique

Un consentement DSP2 valide peut être **insuffisant au regard du RGPD** s'il n'est pas informé et spécifique, ou si les durées de conservation ne sont pas justifiées. Les projets Open Banking doivent embarquer les deux dimensions dès la conception.

BASCULE

Avant / Après : la même intention, deux chemins

Lyam veut toujours voir ses comptes au même endroit. Ce qui change, ce n'est pas son besoin : c'est le chemin

emprunté.

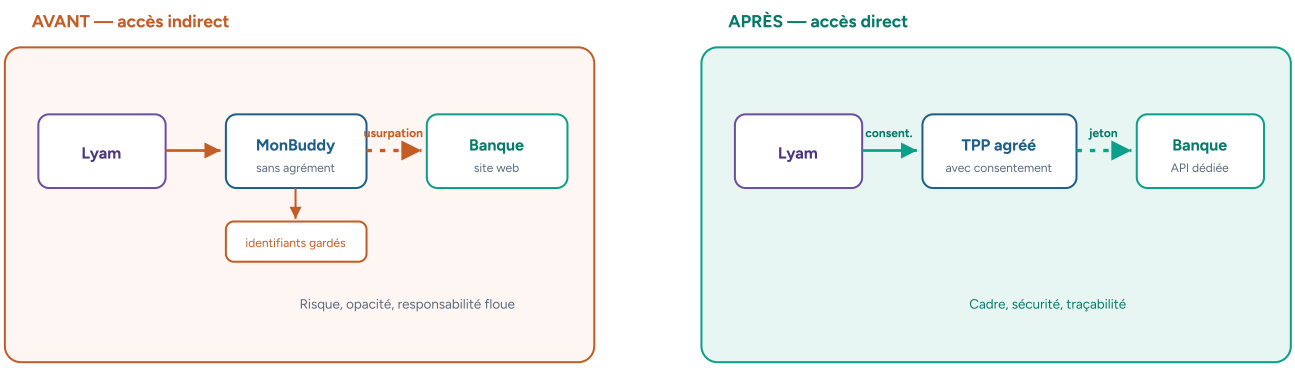


Figure — même besoin, deux chemins : l'accès indirect (avant) et l'accès direct encadré (après).

SÉQUENCE SUIVANTE

Que change la DSP2 ?

La DSP2 va répondre à trois questions, traitées en S2 : **qui** peut accéder aux comptes de Lyam (les nouveaux acteurs), **comment** l'accès est organisé (consentement, authentification), et **à quelles conditions** (accès libre pour les tiers agréés, obligations de la banque, rôle des autorités).

EXERCICE DE SÉQUENCE — 10 MIN, EN BINÔMES

1. Reprenez l'histoire de Lyam et identifiez **les trois acteurs** en jeu avant la DSP2. Qui protège quoi ?
2. Le cas de Lyam est-il **un cas de fraude** ? Justifiez en distinguant trois choses : la sécurité de la donnée, la responsabilité, la qualité de service.
3. Proposez **une mesure** qui aurait évité l'incident de Lyam, sans l'empêcher d'utiliser MonBuddy.
4. Un consentement recueilli par MonBuddy suffirait-il au regard du RGPD ? Justifiez en deux lignes.

Objectif : faire émerger, par les étudiants, les concepts qui seront formalisés en S2 — délégation, consentement, responsabilité limitée, finalité.

08 · S2 · LA RÉPONSE

S2 · La réponse

LA DIRECTIVE ET SES NOUVEAUX ACTEURS

La réponse

La DSP2 apporte une réponse au problème de Lyam : un cadre qui autorise l'accès aux comptes par des tiers, avec le consentement du client — et qui fait entrer de nouveaux rôles dans l'écosystème.

FIL ROUGE

Lyam ne change pas de banque. Il veut toujours voir ses comptes au même endroit — mais cette fois, *sans donner ses identifiants*. La DSP2 est ce qui rend cela possible.

LE TEXTE

La DSP2 en une définition

> La **directive (UE) 2015/2366**, dite **DSP2** (Revised Payment Services Directive), adoptée le **25 novembre 2015**, remplace et étend la DSP1. Elle impose aux banques une **interface dédiée** aux tiers agréés, encadre l'authentification forte et interdit l'accès par identifiants partagés.

Transposée en droit français par l' **ordonnance n° 2017-1252 du 9 août 2017**, elle est entrée en application le **13 janvier 2018** pour les nouveaux services, et les exigences d'authentification forte ont pris leur forme opérationnelle le **14 septembre 2019**.

COURS — REPÈRES CHRONOLOGIQUES

JALON	DATE
Publication DSP2	25 nov. 2015
Transposition FR	9 août 2017
Entrée en application	13 janv. 2018
RTS SCA	14 sept. 2019

SCÉNARIO

Qui fait quoi ? Suivons Lyam, un samedi matin

Avant de nommer les rôles, regardons ce qui se passe quand Lyam utilise l'application. Chaque nouveau mot correspond à un rôle qui agit dans le scénario.

Lyam	ouvre l'application pour voir ses deux comptes au même endroit. Il choisit sa banque et clique « connecter ».
L'application	demande à Lyam l'autorisation de lire ses comptes — en précisant *quels* comptes et *pendant combien de temps*. Ce n'est plus un partage d'identifiants.
La banque	affiche elle-même l'écran de connexion. Lyam s'authentifie *chez sa banque*, jamais chez l'application. La banque vérifie aussi que l'application est bien agréée.
Lyam	valide l'accès en lecture pour 90 jours. Il voit ses comptes. Il peut, à tout moment, révoquer cet accès depuis sa banque.

Ce scénario à quatre actes contient tous les rôles de la DSP2. Nommons-les maintenant.

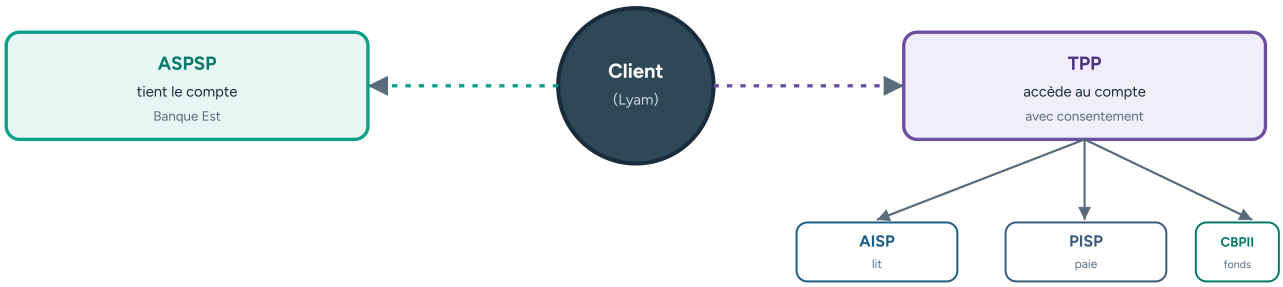
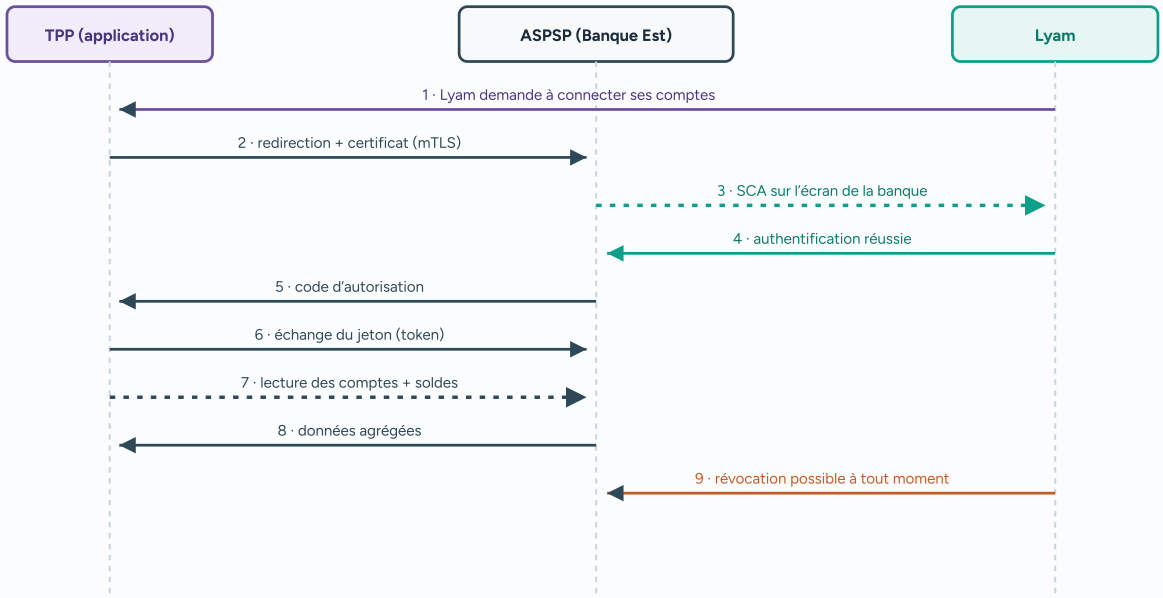


Figure — le client au centre ; l'ASPSP tient le compte, le TPP y accède. Les trois services TPP (AISP, PISP, CBPII) en sont les déclinaisons.

Diagramme de séquence — le parcours de Lyam



ASPSP

ACCOUNT SERVICING PAYMENT SERVICE PROVIDER

La banque qui **tient le compte**. Ici : Banque Est. Elle ouvre une interface aux tiers, gère les consentements et authentifie Lyam.

COURS — OBLIGATIONS & INTERDITS

Obligations : ouvrir une interface dédiée conforme (RTS) ; garantir la disponibilité et la performance ; authentifier l'accès aux comptes sans discriminer un TPP agréé ; vérifier l'agrément des TPP (registre EBA).

Interdits : exiger des TPP une autre voie d'accès que l'interface dédiée (hors dispositif de contingence) ; imposer un contrat bilatéral comme condition d'accès ; bloquer un TPP agréé sans motif objectif.

TPP

THIRD PARTY PROVIDER

Le **tiers agréé** qui accède au compte au nom de Lyam. Ici : l'application. Elle est autorisée, mais ne détient jamais l'argent ni les identifiants.

COURS — LE STATUT PSP

Un TPP est un **prestataire de services de paiement (PSP)** agréé par une autorité nationale (en France, l'ACPR). Sans agrément, aucun droit d'accès. L'agrément couvre un service précis : AIS, PIS ou CBPII.

AISP

ACCOUNT INFORMATION SERVICE PROVIDER

Le TPP qui **lit les comptes** : soldes, opérations. Ici : c'est le service utilisé par Lyam le samedi matin.

COURS — MODÈLE D'AFFAIRES & LIMITES

Modèle d'affaires : abonnement, freemium, données agrégées enrichies, scoring pour des partenaires (avec base légale RGPD).

Ce qu'il ne peut pas faire : initier un paiement (c'est le PISP), modifier le compte, ni détenir les fonds. Il n'a qu'une vue en lecture.

PISP

PAYMENT INITIATION SERVICE PROVIDER

Le TPP qui **déclenche un virement** au nom du client, sans détenir les fonds. Même Lyam, plus tard, quand elle paiera un marchand par virement.

COURS — NON-DÉTENTION DES FONDS

La règle d'or : le PISP ne détient *jamais* les fonds du client, à aucun moment du flux. Il ne peut pas modifier le montant ni le bénéficiaire une fois la SCA effectuée. Il ne lit pas l'historique (ce n'est pas un AISP).

Usages : paiement e-commerce par virement, paiement de facture, recharge de wallet.

COURS — LE QUATRIÈME SERVICE : CBPII

Le **CBPII** (Card-Based Payment Instrument Issuer) confirme à un émetteur de carte la *disponibilité des fonds* sur un compte, sans exposer les soldes. C'est le plus rare des services TPP : il *vérifie* des fonds, là où le PISP *déclenche* un paiement.

SERVICE	LIT LE COMPTE	DÉCLENCHE UN PAIEMENT	VÉRIFIE DES FONDS
AISP	Oui	Non	Non
PISP	Non	Oui	Non
CBPII	**Non (soldes non exposés)**	**Non**	**Oui**

Les deux mots à ne jamais confondre

ASPSP = celui qui tient le compte et le sert. **TPP** = celui qui y accède avec l'autorisation de Lyam. Tous les AISP, PISP et CBPII sont des TPP — mais l'ASPSP n'en est pas un.

RELATIONS

Trois relations structurantes

Trois relations structurent l'échange. Dans le scénario de Lyam, elles sont toutes visibles.

1

Banque ↔ fintech

Banque Est et l'application ne sont pas concurrentes sur le compte, mais **partenaires obligés** par la directive. La banque doit laisser l'application agréée accéder au compte ; l'application doit se conformer aux règles d'accès.

2

Banque ↔ API

La banque n'expose pas son SI, mais une **interface dédiée** (API) aux tiers. C'est ce canal qui remplace le « je passe par le site comme un humain » du screen scraping.

3

Client ↔ consentement

Lyam n'autorise plus « un accès » : il donne un **consentement explicite**, borné dans le temps et le périmètre, qu'il peut révoquer. C'est le nouveau point de contrôle de toute la relation.

OBJECTIFS

Ce que la DSP2 cherche à obtenir

Derrière les acteurs et les relations, la directive poursuit trois objectifs. On peut les rattacher directement à l'histoire de Lyam.

01

Stimuler la concurrence

> *Pour Lyam : il peut enfin comparer ses deux banques dans une seule application.*

En rendant les comptes accessibles aux tiers agréés, la DSP2 casse la rente du verrouillage. Des offreurs **non bancaires** peuvent se placer dans la relation client sans créer une banque.

02

Favoriser l'innovation

> *Pour Lyam : l'application peut proposer bien plus que « voir ses comptes ».*

Des **interfaces normalisées** et des API dédiées permettent des services nouveaux : gestion budgétaire, trésorerie, scoring. On remplace l'automatisation d'écrans, fragile, par un socle stable.

03

Protéger le consommateur

> *Pour Lyam : plus jamais de partage d'identifiants, et un accès révocable.*

L'authentification forte (**SCA**) devient la règle. Le client donne un consentement explicite, peut le révoquer, et les tiers sont **agréés et supervisés**.



Figure — les trois objectifs de la DSP2 : concurrence, innovation, protection du consommateur.

Nuance à ne pas rater

La DSP2 n'impose pas aux banques de donner gratuitement leurs données à n'importe qui. Elle impose de laisser **un tiers agréé** accéder aux comptes **d'un client qui l'a autorisé**. C'est une ouverture régulée, pas un libre-service.

OBJECTIF	LEVIER RÉGLEMENTAIRE	IMPACT SI	INDICATEUR D'ÉCHEC
Concurrence	Ouverture des comptes aux TPP agréés	APIs de comptes (AIS) et de paiement (PIS)	APIs instables, contournées par screen scraping
Innovation	Interfaces dédiées, suppression du screen scraping	API Gateway, portail développeur, sandbox	Plus de 6 mois pour mettre en ligne un nouveau service
Protection	**SCA, consentement, supervision**	**IAM, consent management, orchestration SCA**	**Fraude en hausse, consentements non révocables**

MODÈLE

La banque plateforme

Si Banque Est ne fait que le minimum, elle « subit » la DSP2. Si elle prend le virage, elle devient une **plateforme** : elle expose ses capacités (comptes, paiements, identité) à des partenaires, et reste au centre du flux.

Trois états de la banque



GOUVERNANCE

Qui fait appliquer la DSP2 ?

La directive n'est pas appliquée par une seule institution. Les autorités européennes jouent un rôle central, en particulier l'**EBA**.

INSTITUTION	RÔLE	PRODUCTION UTILE
Commission européenne	Propose et révise les directives	Texte DSP2, travaux DSP3
EBA	**Normes techniques et orientations**	**RTS SCA, registre central des PSP**
ACPR (France)	Agrément et supervision des PSP	Agréments, registre national, contrôles

Ce que l'EBA fait concrètement

L'EBA produit les **RTS** (exigences d'authentification forte), les **orientations** sur les interfaces, et le **registre central** qui permet à une banque de vérifier qu'un TPP est bien agréé — point crucial que l'on retrouvera au bloc 1.3.

RTS — normes techniques

Force obligatoire dès adoption : authentification forte, exemptions, communication sécurisée entre ASPSP et TPP. C'est le socle opérationnel de la DSP2.

Orientations (guidelines)

Interprétations sur les obstacles à l'accès, les interfaces dédiées, les parcours de redirection. Non contraignantes en théorie, suivies en pratique.

Le registre central, un composant de sécurité

Une architecture Open Banking sérieuse ne vérifie pas un TPP « à la main ». Elle interroge le **registre EBA** (ou national) à chaque nouvel appairage, puis met le résultat en cache avec une durée de validité. C'est un mécanisme de sécurité à part entière, pas un détail administratif.

SÉQUENCE SUIVANTE

Comment ça marche, concrètement ?

On sait *qui* agit et *pourquoi*. Reste le *comment* : la chaîne technique qui relie l'application de Lyam au core banking de Banque Est, et la façon dont la banque protège chaque maillon. C'est l'objet de la S3.

09 · S3 · LA MACHINE

S3 · La machine

ARCHITECTURE CIBLE ET STANDARDISATION

La machine

Comment l'application de Lyam parle-t-elle à Banque Est sans jamais toucher au core banking ? Cette séquence ouvre le capot et suit l'appel, maillon par maillon.

FIL ROUGE Samedi, 9 h 12. Lyam rouvre l'application. Son téléphone envoie une requête à Banque Est. Que se passe-t-il avant que le solde apparaisse à l'écran ?

PRINCIPE

Ne jamais toucher le core banking

Le core banking est le système qui tient les comptes. Il est **critique, lent et monolithique**. Si on le laisse joindre par des tiers, on ouvre la porte aux pannes et aux intrusions.

LA CHAÎNE COMPLÈTE

Client → TPP → API Banque → Core Banking. Mais entre « API Banque » et le core, il y a plusieurs couches qui font office de sas de sécurité.

ARCHITECTURE LOGIQUE

Les cinq couches SI

Cinq couches structurent l'architecture. Chacune a un rôle unique, et l'on retrouve leur enchaînement dans le parcours de Lyam.

1 **API Gateway**

Le guichet d'entrée. Reçoit la requête, termine le chiffrement (mTLS), vérifie les quotas, bloque les abus. Aucun appel n'atteint le reste sans passer par elle.

2 **Consent management**

Le registre des autorisations. Stocke le consentement de Lyam : quels comptes, jusqu'à quand, quel périmètre. À chaque appel, vérifie que la demande est bien couverte.

3 **Identity & Access Management (IAM)**

Le contrôle des identités. Gère l'authentification de Lyam (SCA), les jetons OAuth2, et l'identité technique du TPP. C'est ici que l'on s'assure que l'application est bien celle qu'elle prétend être.

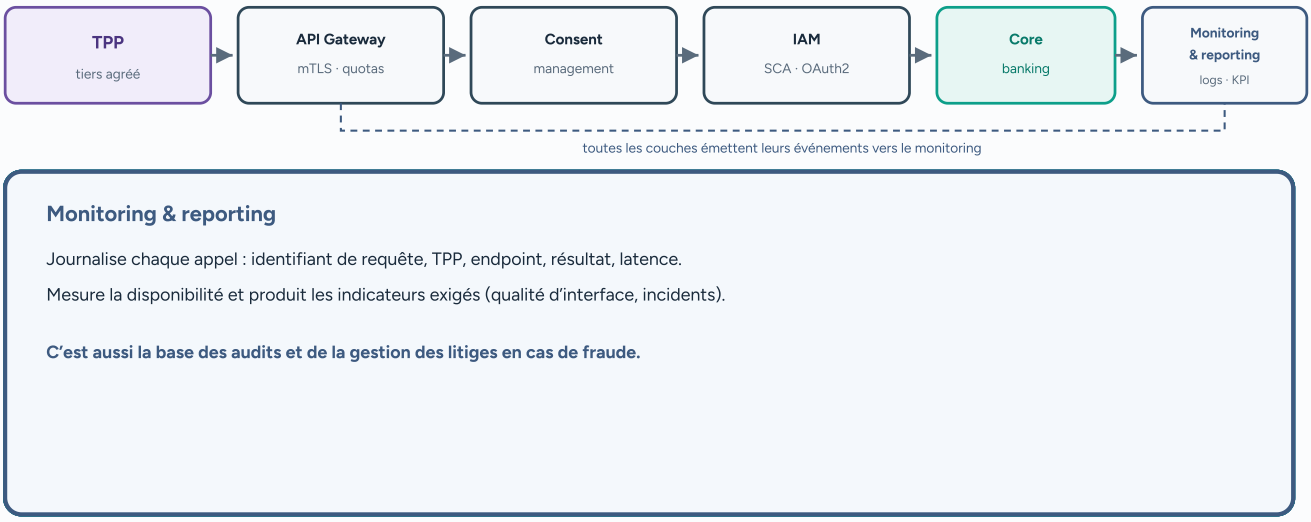
4 Core banking

Le système de tenue de compte. Reçoit des appels internes déjà filtrés : lit le solde, écrit une opération. Il n'a jamais connaissance de la notion de TPP.

5 Monitoring & reporting

La mémoire de l'ensemble. Journalise chaque appel (qui, quand, quoi, résultat), mesure la disponibilité et la latence, produit les rapports exigés par l'ACPR.

Les cinq couches en chaîne



Pourquoi cinq couches et pas une seule API ?

Parce que chaque couche répond à une exigence DSP2 distincte. La Gateway prouve l'identité du TPP, le Consent management la légitimité de l'accès, l'IAM l'identité du client, le Core exécute, le Monitoring rend des comptes. Fusionner ces rôles, c'est empiler les risques.

DÉROULÉ

Le parcours de Lyam, maillon par maillon

01 **Gateway** — l'application se présente avec son certificat ; la Gateway vérifie qu'elle est connue et l'agrément est contrôlé.

02 **Consent management** — la Gateway demande si Lyam a bien autorisé ce périmètre ; réponse oui, jusqu'au 12 mars.

03 **IAM** — si la session en cours est valide (jeton OAuth2), on passe ; sinon, redirection pour une SCA.

04 **Core banking** — l'appel filtré est traduit en lecture de solde et d'opérations.

05 **Monitoring** — un événement complet est enregistré, y compris le temps de réponse.

06 **Retour** — la réponse sort par la Gateway et s'affiche dans l'application de Lyam.

AIS (LECTURE) VS PIS (PAIEMENT)

CRITÈRE	AIS	PIS
Effet	Aucun mouvement de fonds	Mouvement de fonds
SCA	Tous les 90 jours	À chaque paiement (sauf exemption)
Fréquence	4 consultations/jour sans SCA	Un consentement = un paiement
Cache	Recommandé	Interdit

LE PARCOURS DE REDIRECTION EN 7 ÉTAPES

Le cœur technique de la DSP2 : le client doit s'authentifier sur le site de sa banque, jamais chez le TPP.

1. **Initiation chez le TPP** — le client clique « payer/connecter par ma banque ».
2. **Redirection** — le TPP renvoie vers l'ASPSP avec son identifiant et un paramètre d'état.
3. **Authentification** — le client saisit ses identifiants puis réalise la SCA (code, notification).
4. **Consentement** — l'ASPSP affiche le TPP, les comptes et la portée, puis demande validation.
5. **Autorisation** — l'ASPSP génère un code que le TPP échange contre un jeton.
6. **Exécution** — le TPP appelle l'API jusqu'à l'expiration.
7. **Retour** — le client est redirigé vers le TPP avec le résultat.

Intégration vs redirection : certains ASPSP proposent une *intégration embarquée* (SCA dans l'app du TPP) ou une *approche découplée* (SCA dans l'app bancaire). Le parcours de redirection reste le socle commun que tout le monde doit supporter.

QUALITÉ DE SERVICE

Une interface de qualité, ça se mesure

La conformité DSP2 ne suffit pas : une interface peut être « légale » et inutilisable. Les régulateurs regardent des indicateurs objectifs.

Indicateurs mesurés

- Taux de disponibilité mensuel (souvent > 99 %)
- Temps de réponse p95 par endpoint
- Taux d'erreur 5xx
- Nombre d'incidents et durée moyenne de rétablissement

Signaux d'une interface insuffisante

- Maintenance en heures ouvrées sans publicité
- Erreurs génériques sans identifiant de requête
- Absence de sandbox ou documentation obsolète
- Plafonds de débit appliqués sans transparence

INDICATEUR	CIBLE USUELLE	POURQUOI C'EST CRITIQUE POUR LYAM
Disponibilité	> 99 %	Sinon l'app affiche une erreur ce matin-là
Latence p95	< 500 ms	Sinon le solde met plusieurs secondes à apparaître
Taux 5xx	**< 0,5 %**	**Sinon les soldes sont partiels, l'agrégation faux**

STANDARDISATION

Pourquoi standardiser ?

trois raisons de standardiser.

Interopérabilité

Une même application peut parler à plusieurs banques sans réécrire son code pour chacune. Sans standard : une intégration par banque.

Sécurité

Un standard éprouvé embarque les bons mécanismes d'authentification et de consentement. Réinventer le format, c'est aussi réinventer ses failles.

Time-to-market

Pour Banque Est, exposer une API standardisée, c'est rendre un nouveau partenaire opérationnel en **quelques semaines** au lieu de plusieurs mois.

Le point que beaucoup oublient

La standardisation est un enjeu de **modèle d'affaires**, pas seulement de technique. Pour l'application de Lyam qui veut couvrir 200 banques, une API propriétaire par banque, c'est 200 intégrations à maintenir.

Les deux grandes initiatives

Open Banking Implementation Entity

OBIE (Royaume-Uni), devenue *Open Banking Limited* : standards obligatoires pour les grandes banques britanniques, très détaillés, avec tests de conformité. *Ne s'applique pas en France.*

Berlin Group

NextGenPSD2 : standard volontaire, REST JSON, largement adopté en zone euro (dont la France et l'Allemagne). C'est le standard de fait côté continental.

API PROPRIÉTAIRES VS API STANDARDISÉES

CRITÈRE	STANDARDISÉE	PROPRIÉTAIRE
Pour le TPP	Une intégration utile pour toutes les banques	Une intégration par banque
Pour la banque	Time-to-market court, écosystème	Contrôle total, spécificité interne
Risque	Variantes locales, coût de migration	Effort d'intégration pour les TPP

La DSP2 n'exige aucun format. Ce qui est exigé, c'est l'**accès effectif** par une interface dédiée.

L'erreur classique

Croire que « OBIE est obligatoire en France ». C'est faux. OBIE est un standard national britannique. En France, l'ACPR n'impose pas un format unique : elle exige une interface conforme aux RTS et réellement accessible.

FAUT-IL UN STANDARD UNIQUE ?

Pour un standard unique

- Réduction du coût d'intégration pour les TPP
- Comparabilité des performances entre banques
- Moins d'ambiguïtés pour les audits

Contre

- Rigidité face aux spécificités nationales
- Coût de migration pour les banques en production
- Un standard figé peut freiner l'innovation

Position raisonnable : les régulateurs n'imposent pas un format précis mais exigent l'*interopérabilité* — documentation publique, sandbox, versionnement stable, tests de conformité. C'est ce que renforcent la révision DSP3 et le règlement FIDA.

Grille d'arbitrage en pratique :

1. Réglementation — obligations du pays du siège
2. Partenaires — ce que demandent les TPP qui ciblent la banque
3. Existant — l'API interne est-elle déjà REST/JSON ?
4. Coût — implémentation, tests, maintenance
5. Risque — impact d'une non-conformité
6. Valeur — la standardisation ouvre-t-elle des usages ?